

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

New BOLDMOVE Backdoor uses FortiOS vulnerability for initial access

Date of Publication

January 20, 2023

Admiralty Code

A1

TA Number

TA2023034

Summary

First appeared: October 2022

Attack Region: Europe and Africa

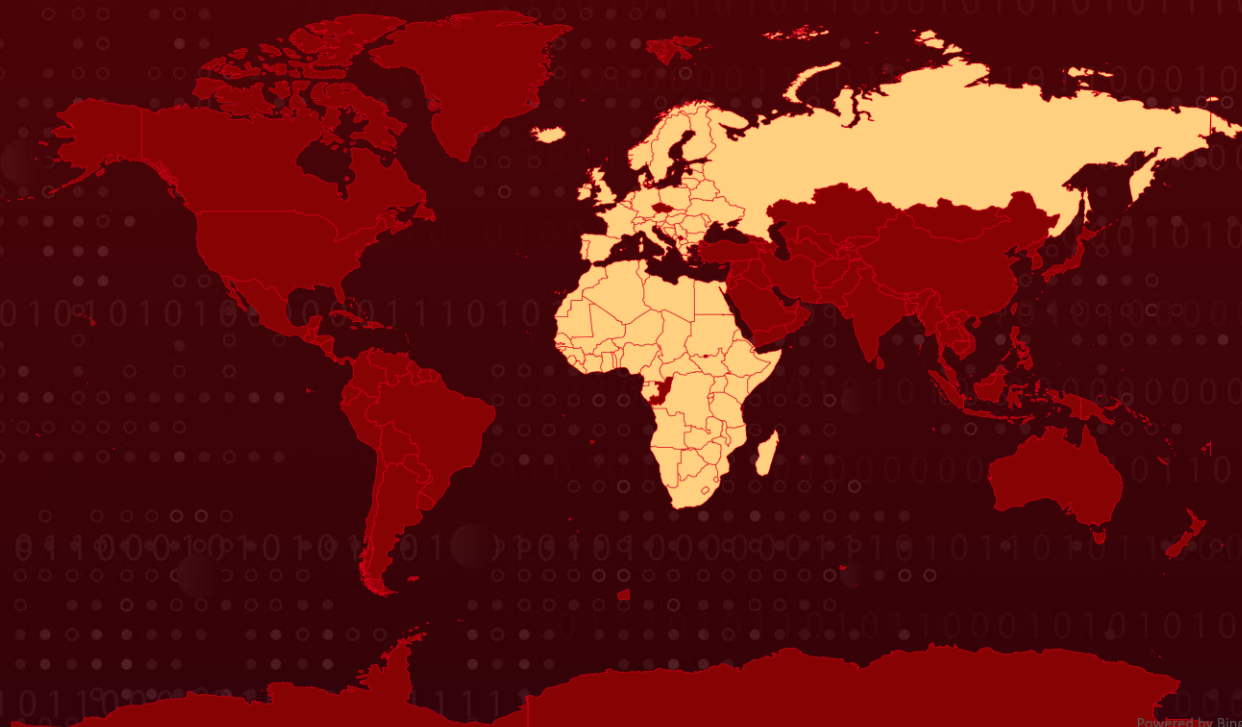
Affected Product: FortiOS

Attack: CVE-2022-49475 was exploited by unknown Chinese threat actors to deliver BOLDMOVE backdoor.

⚙️ CVE

CVE	NAME	PATCH
CVE-2022-42475	Remote code execution in FortiOS sslvpnd	✅

🗡️ Attack Regions



Powered by Bing

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

A suspected China-nexus campaign has exploited a vulnerability in Fortinet's FortiOS SSL-VPN, known as CVE-2022-42475. The exploitation was believed to have occurred as early as October 2022 and the targets include a European government entity and a managed service provider in Africa. The malware used in the attack has been identified as "BOLDMOVE" is written in C and has both Windows and Linux variants, the latter of which is intended to run (at least in part) on Fortinet devices as it reads data from a file that is proprietary to Fortinet.

#2

The malware is believed to have been used to gain access to targeted networks without requiring any victim interaction, allowing the attackers to control the timing of the operation and decrease the chances of detection. The malware also appears to have an in-depth understanding of systems, services, logging, and undocumented proprietary formats which allows the attackers to move laterally into a network and enable command and control (C2) by tunneling commands in and data out of a network.

#3

This type of attack is consistent with previous Chinese cyber espionage operations that have targeted internet-facing devices and it is likely that this tactic will continue to be used in the future.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0005</u> Defense Evasion	<u>TA0007</u> Discovery	<u>TA0011</u> Command and Control
<u>T1129</u> Shared Modules	<u>T1027</u> Obfuscated Files or Information	<u>T1082</u> System Information Discovery	<u>T1124</u> System Time Discovery
<u>T1518</u> Software Discovery	<u>T1518.001</u> Security Software Discovery	<u>T1016</u> System Network Configuration Discovery	<u>T1033</u> System Owner/User Discovery
<u>T1087</u> Account Discovery	<u>T1070</u> Indicator Removal	<u>T1070.004</u> File Deletion	<u>T1071</u> Application Layer Protocol
<u>T1573</u> Encrypted Channel	<u>T1059</u> Command and Scripting Interpreter	<u>T1562</u> Impair Defenses	

Indicators of Compromise (IOCs)

TYPE	VALUE
MD5	12e28c14bb7f7b9513a02e5857592ad7 3191cb2e06e9a30792309813793f78b6 54bbea35b095ddfe9740df97b693627b
SHA1	3da407c1a30d810aaff9a04dfc1ef5861062ebdf0e6d0f6823ca682c a08c37da 0184e3d3dd8f4778d192d07e2caf44211141a570d45bb47a87894c 68ebebeabb 61aae0e18c41ec4f610676680d26f6c6e1d4d5aa4e5092e40915fe8 06b679cd4

Patch Link

<https://www.fortiguard.com/psirt/FG-IR-22-398>

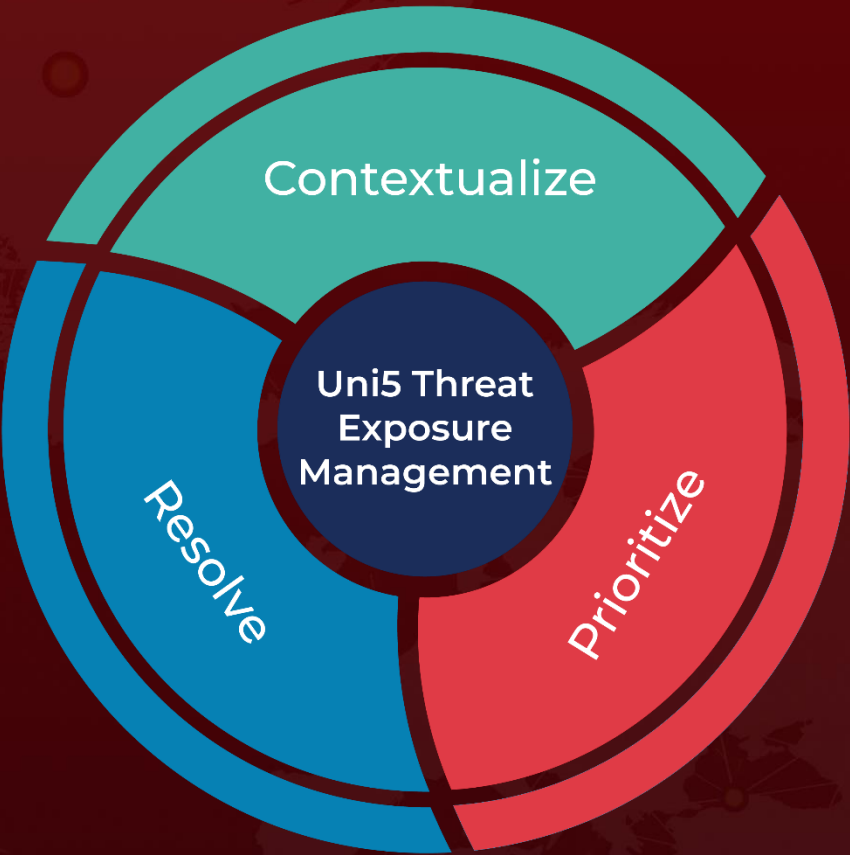
References

<https://www.mandiant.com/resources/blog/chinese-actors-exploit-fortios-flaw>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

January 20, 2023 • 5:35 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com